

Christian Romo

COMP 348

3/13/2026

Project 2

Issue: Lack of a comprehensive identity management - Password resets (self-service and service desk assisted) feature for corporate Active Directory (AD) accounts. From what I researched, this is an important security concern, and attackers can easily abuse a password reset feature if it does not comply with the procedure below.

Scope: The scope of the procedures includes corporate employee and contractor accounts in an enterprise AD environment. It includes hybrid identity systems that use a self-service password reset (SSPR) portal with a password writeback to an onsite AD. The scope does not include other types of accounts including privileged or administrator accounts, as these require more secure practices. Procedure protection includes passwords, MFA methods, recovery information, reset tickets and audit logs.

Published Standard: I based my documentation on **NIST SP 800-63B** and **Microsoft Entra ID**, which gives lots of guidance on password handling, account recovery and rate limiting. The main takeaway is that security questions are weaker in comparison to MFA, recovery codes, or controlled identity proofing.

Procedure:

1. Confirm the account is in scope and not a privileged or service account.
2. If self-service is available, direct the user to the approved SSPR portal first.
3. Require the user to verify identity via two different methods, such as authenticator app and a phone or email.
4. No security questions as reset methods.
5. After identity is verified, allow the user to create a new password that follows the company password policy.
6. If self-service is not possible, the service desk must open a ticket before proceeding.
7. The service desk must verify the user's identity by using stronger methods, such as an MFA challenge to a registered device, a callback to a known phone number, or formal re-verification if the user lost access to their factors.
8. If verification fails or the request looks suspicious, the reset must be denied and escalated.
9. After a successful reset, the system should send a notification to the user and log the event in both AD and cloud audit logs

Validation:

1. Logs and tickets must be reviewed and reset each month. The organization must confirm that password reset events are being recorded, and that service desk tickets document the verification method used.

2. Organization must test the process quarterly by attempting failed verifications, confirming lockout behavior, and checking that excluded accounts are denied or escalated properly.

References

Justinha. (2023, October 23). Self-service password reset deep dive. Learn.microsoft.com.
<https://learn.microsoft.com/en-us/entra/identity/authentication/concept-sspr-howitworks>

NIST SP 800-63 Digital Identity Guidelines-FAQ. (n.d.). Pages.nist.gov.
<https://pages.nist.gov/800-63-FAQ/>

NIST, Temoshok, D., Fenton, J., Choong, Y.-Y., Lefkovitz, N., Regenscheid, A., Galluzzo, R., & Richer, J. (2017). *NIST SP 800-63 Digital Identity Guidelines*. Nist.gov.
<https://pages.nist.gov/800-63-3/>